

Lab Introduction : Cyber Security 32548/48730

- Tutor name: RISHIKESH VIJAY(Call me Rishi 😊)
- Email: Rishikesh.Vijay-1@uts.edu.au



Lab 1. Lab Setup (1/2)

- The VM Images can be downloaded, extracted and run without any additional setup required and have all the tools pre-installed.
- It is recommended to use an external storage device with at least 64GB space and USB 3.0 standard.
- Using external storage avoids downloading the VM every session as the IT department cleans the system every week.

Lab 1. Lab Setup (2/2)

- The VM can be run directly off the USB stick/External HDD.
- Only the Server VM can access the internet, the Client and Attacker can not in order to isolate any attacks.
- If your VM crashes/doesn't boot-up, you can just get a fresh set. It is advised to keep the downloaded compressed file handy for this purpose.

Lab 1. Marks (1/2)

- The Skill-Based Assessment (SBA) will take place in week 11 and is worth 30% weightage. It is held in the tutorial session with the submission on UTS Canvas.
- Quiz 1 (Takes place in week 5) and Quiz 2 (Takes place in week 9) are worth 10% each and will be held in the tutorial session on UTS Online (questions based on lecture content).
- Lab submissions – 20%
 - Refer to Assignment Window on Canvas for Due Date.
 - Lab marks vary - please see UTS Canvas

Lab1: Marks (2/2)

- Attempt all the tasks and provide screenshots and explanation in support of each task.
- No email submissions will be accepted.NO PHONE SCREENSHOTS – will mark 0 for that week
 - Please upload on UTS Canvas

Notice: Assignment Report

- The assignment report should contain **only questions from the lab manual** along with **your answers** and **screenshot to support your answer**.
- Make sure to write **the task number, task title and question number**.
- Assignment with **only screenshots** without task title, questions from manual and/or explanation will be marked **'ZERO'**.

Intro to Lab Environment

- Go through the first few pages to setup a VM
 - Download all the 3 VM images
 - It comprises of:
 - CyberSec-Server
 - CyberSec-Client
 - CyberSec-Attacker
- Need all 3 VM's for final task
- **Password: cybersec**(for all 3 VM's)

Lab 1. Lab Today

- Cyber Crime Advisement
- Lab Setup
- Marks
- Today's Lab
 - **Password Cracking using John The Ripper(Covering this today)**
 - **SQL Injection(Covering this today)**
 - **Sniffing Login Details from unencrypted HTTP traffic (From Week 1)**
 - **Extracting an image from unencrypted HTTP traffic (From Week 1)**
 - **Information Gathering (From Week 1)**

Task 1: Sniff Login details from unencrypted HTTP Traffic

- Data transmitted through HTTP is vulnerable to interception by malicious actors, who can potentially eavesdrop on unencrypted packets and extract sensitive information such as images, login credentials, or personal data.
- Therefore, cybersecurity professionals employ specialised tools and methodologies, like packet sniffers, to analyse network traffic, identify potential security gaps, and implement robust encryption measures, safeguarding data integrity and preserving user privacy.
- In this practical lab, you will acquire fundamental information gathering skills using Wireshark. Through the analysis of captured network packets, you'll explore the extraction of valuable data transmitted over unencrypted HTTP connections.
- This hands-on experience will equip you with essential tools to identify and understand potential security risks and vulnerabilities, enhancing your expertise in cybersecurity information analysis.

Task 1: Sniff Login details from unencrypted HTTP Traffic

Step 1: Open Wireshark and make sure that promiscuous mode is enabled on all interfaces.

Step 2: Start the capturing of files.

Step 3: Go to: **<http://bias.csr.unibo.it/fvc2004/logon.asp>**

Step 4: Enter **your name/email** as the login username and enter your name as the password. Make sure you hit the logon button.



FVC2004	Logon to Participant Area
Home	User name (e-mail) rishikesh.vijay@student.uts.edu.au
Background	User password
Categories	Logon
Protocol	▶ Forgot your password?
Databases	▶ Questions or problems?
Perf. evaluation	
Participants	
Results	
Download	

Task 1: Sniff Login details from unencrypted HTTP Traffic

Step 5: Utilise the search bar to locate the packet with the login information. **Hint** the packet will be using the HTTP protocol and will start with POST.

Step 6: In Wireshark, locate the login details which are the username and the password you have used for the unsecure website.

Hints: Write **frame contains "POST"** in search bar of Wireshark to look for packet containing the login information.

```
▼ HTML Form URL Encoded: application/x-www-form-urlencoded
  ▶ Form item: "id" = "rishikesh.vijay@student.uts.edu.au"
  ▶ Form item: "pwd" = "rishikesh"
```

Task 2: Extract an image from unencrypted HTTP Traffic

- Wireshark and similar network sniffing tools, offers the ability to extract images from unencrypted packets transmitted via websites that use the HTTP protocol or other unencrypted protocols.
- This capability allows experts to identify potential vulnerabilities, assess data leakage risks, and bolster network security, strengthening overall digital resilience and ensuring the protection of sensitive information effectively.
- In practice, experts in industry use a number of tools to extract such information.

Homework Task: Task 2: Extract an image from unencrypted HTTP packet

- You are tasked to extract the logo image of the same website(<http://bias.csr.unibo.it/fvc2004/logon.asp>) we have entered previously. Use the same packets captured from task 1.

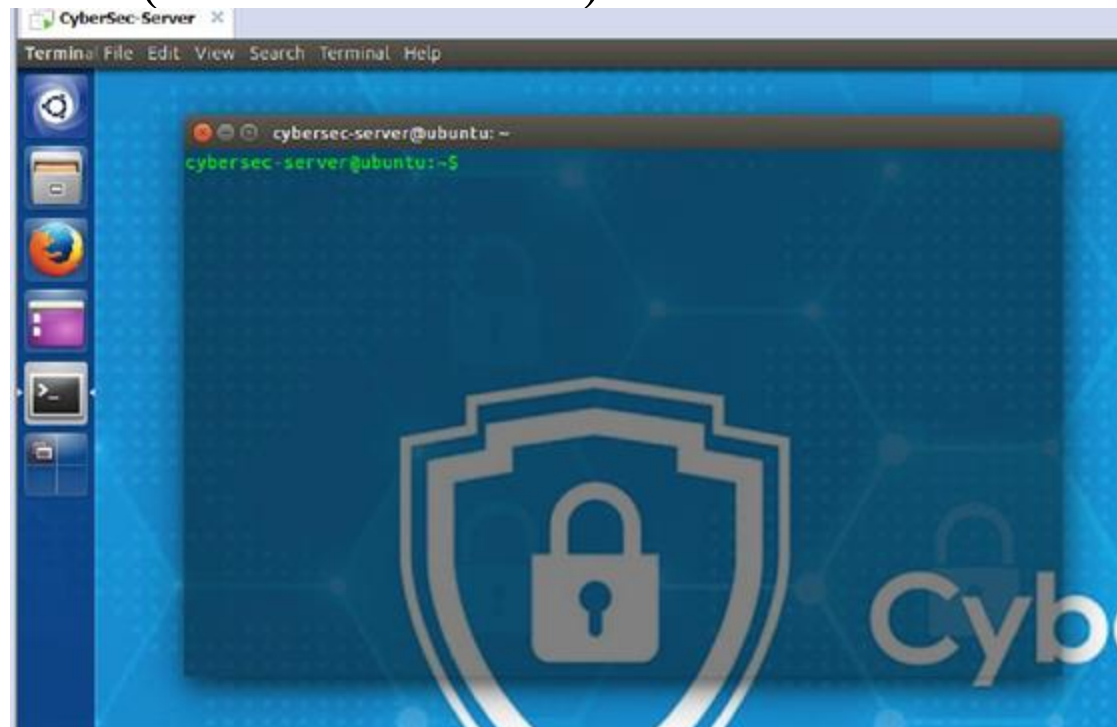
Hint: Write **frame contains "GET"** in search bar of Wireshark to look for packet containing the image information.

Note: If the image file is not found on the HTTP object list, repeat the task by accessing the webpage on the web browser using incognito or private mode.

REFER TO THE LAB HANDOUT FOR THE STEPS

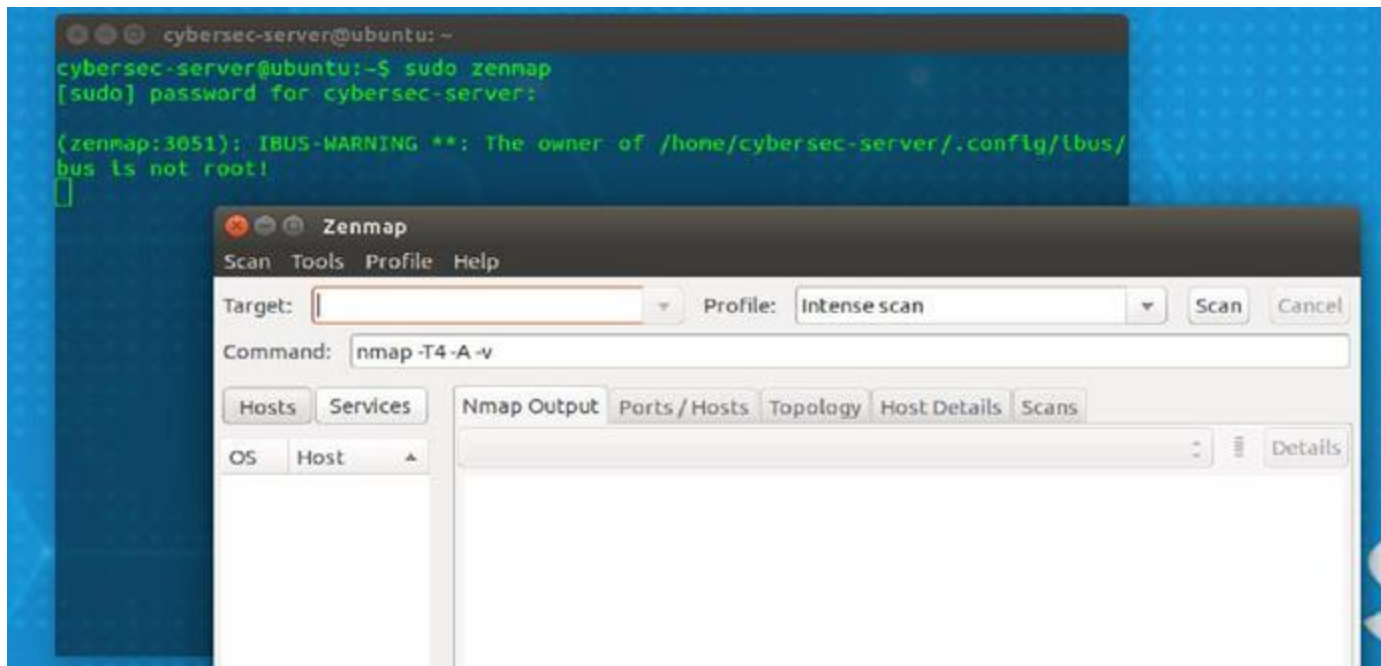
Task 3: Information Gathering

- Only required: CyberSec-Server VM
- Step 1: Boot up the image and run the Terminal
 - (or Ctrl + Alt + T)



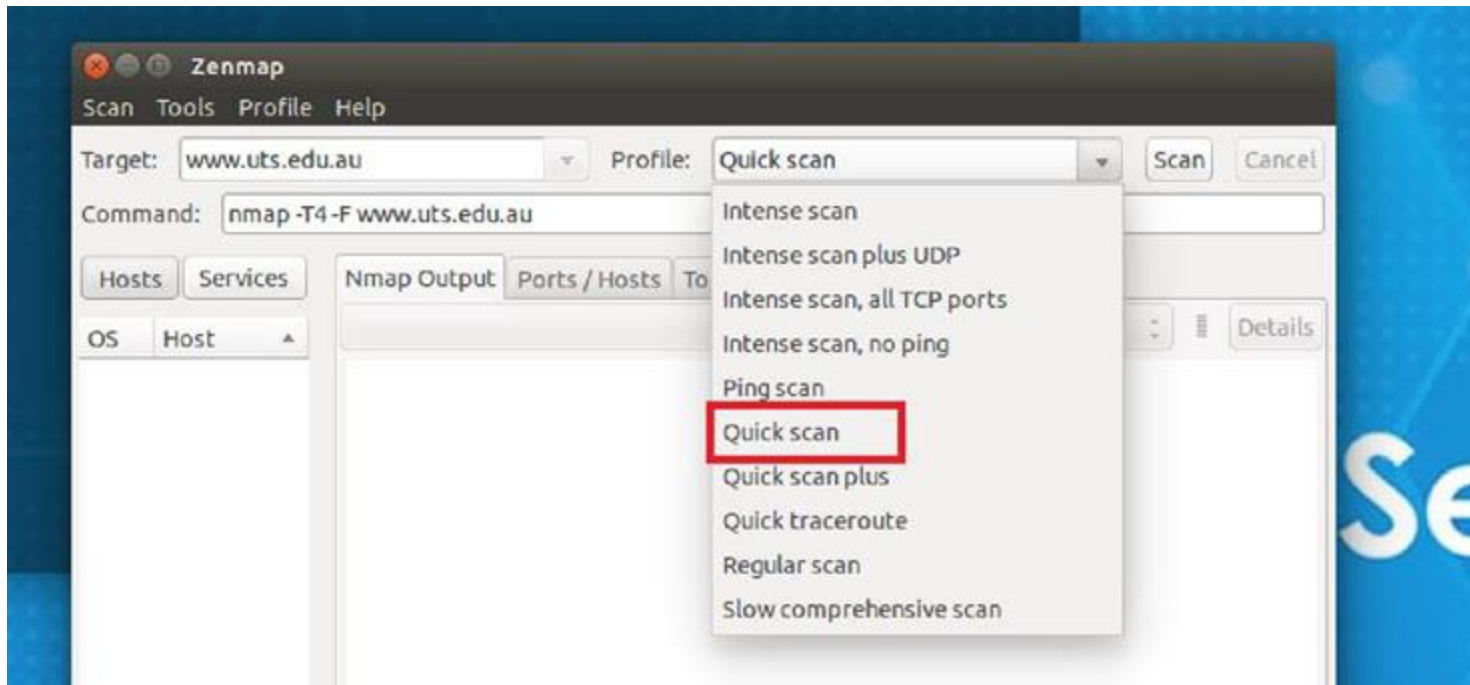
Task 3: Information Gathering

- Step 2: Run Zenmap from the terminal using
 - sudo zenmap
 - (enter password: cybersec when prompted)



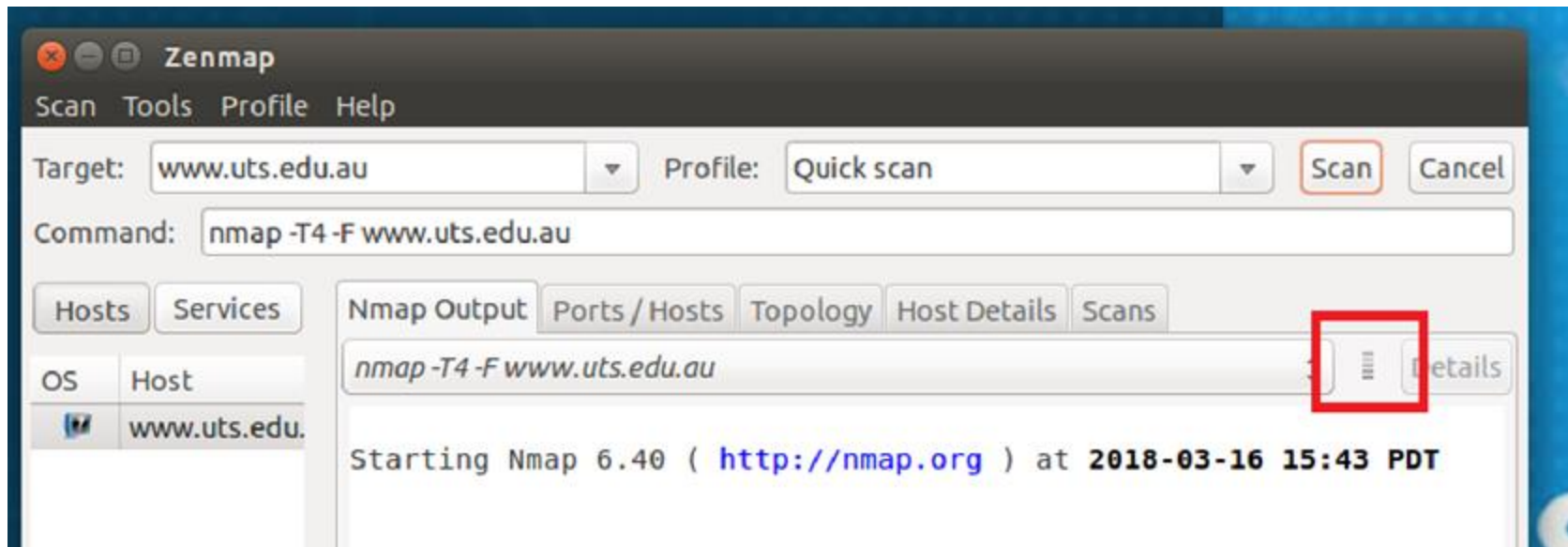
Task 3: Information Gathering

- Step 3: Use Target field to enter the website name (www.uts.edu.au) and under the profile list, select **quick scan** and finally click on scan.



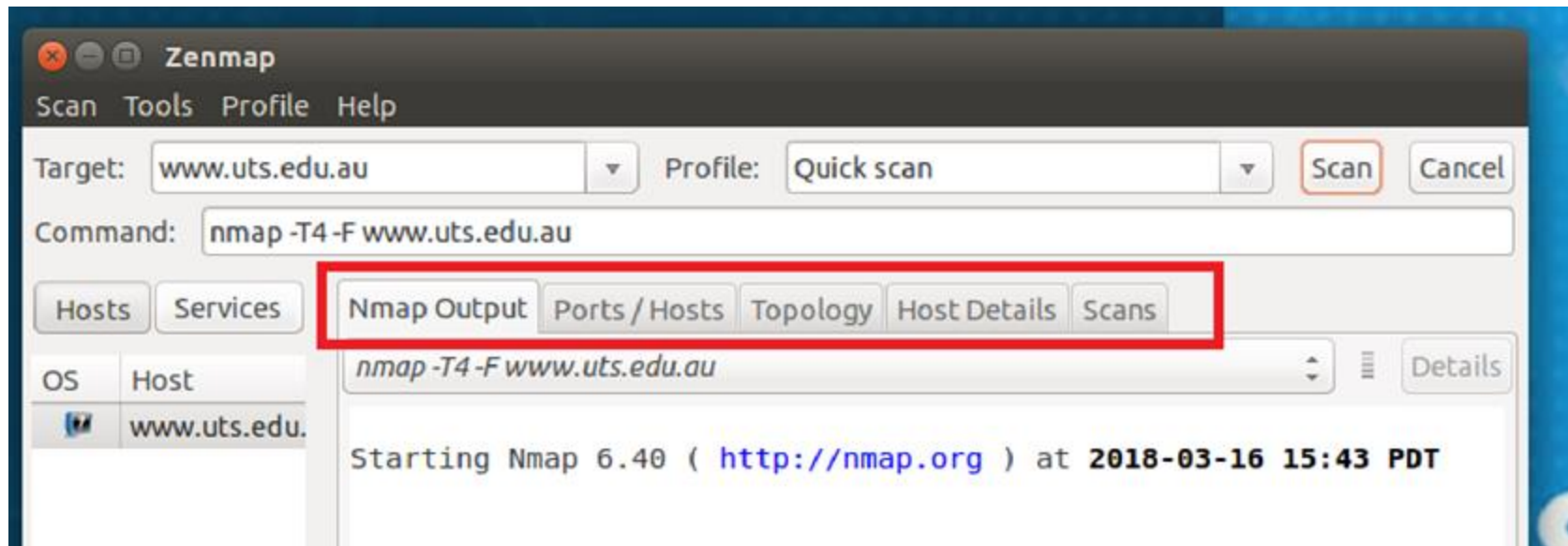
Task 3: Information Gathering

- Whether it is working? (how to confirm)



Task 3: Information Gathering

- Use tabs to navigate and gather information



Nmap Output: Shows the command line version of the scans and information

Task 3: Information Gathering

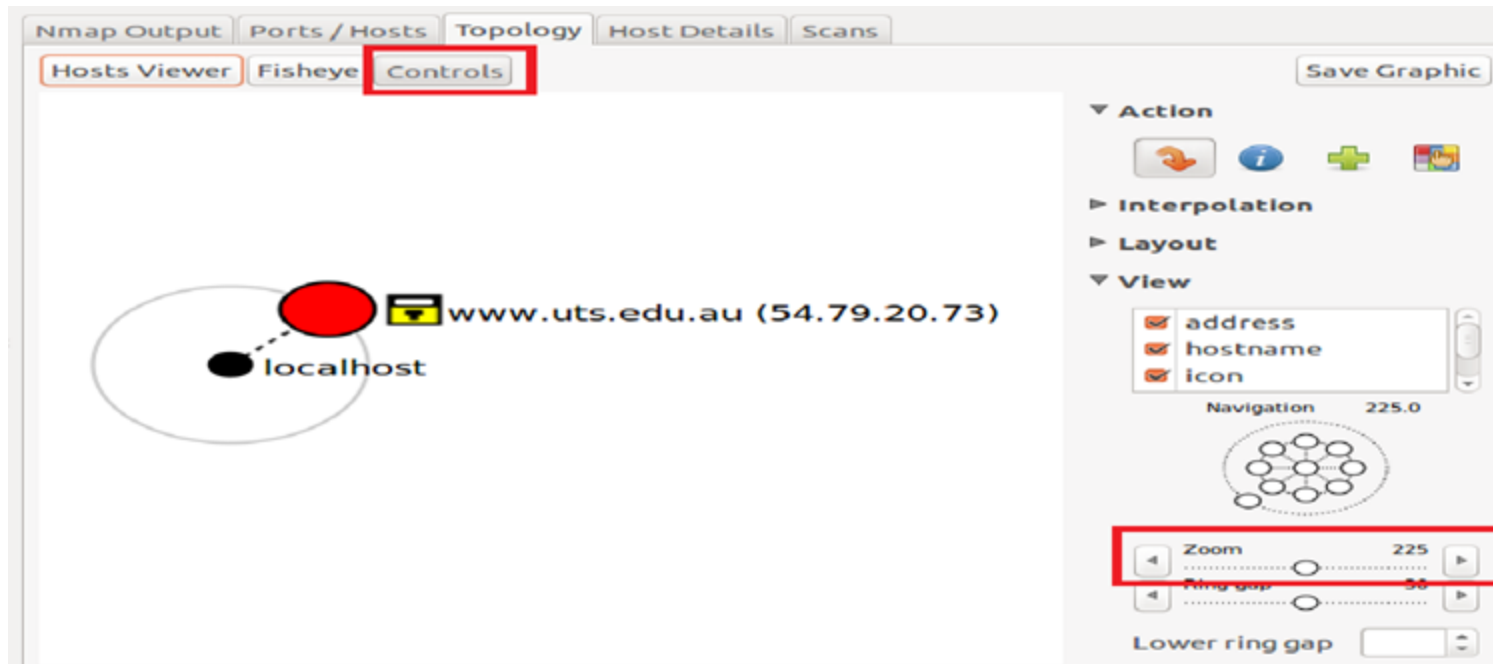
- Use tabs to navigate and gather information

Nmap Output					
Ports / Hosts					
Topology					
Host Details					
Scans					
	Port	Protocol	State	Service	Version
✓	22	tcp	open	ssh	
✓	25	tcp	open	smtp	
✓	80	tcp	open	http	
✓	110	tcp	open	pop3	
✓	143	tcp	open	imap	
✓	443	tcp	open	https	
✓	587	tcp	open	submission	
✓	993	tcp	open	imaps	
✓	995	tcp	open	pop3s	
✓	119	tcp	open	nntp	

Ports/Hosts: Shows any/all the ports the target is using and their status and service

Task 3: Information Gathering

- Use tabs to navigate and gather information



Topology: Shows the hops taken to reach the target.

Note: Use the Controls button to get control menu, using which Zoom feature can be accessed.

Task 3: Information Gathering

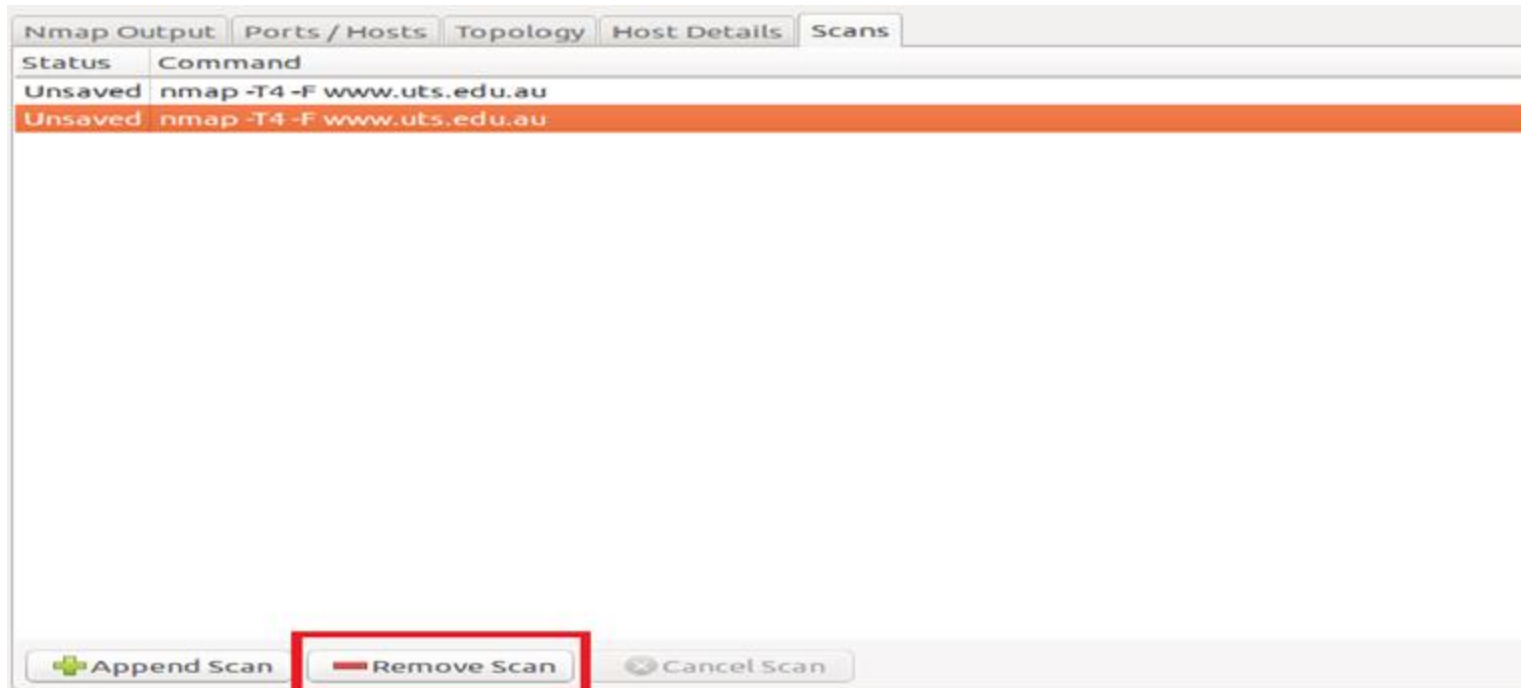
- Use tabs to navigate and gather information



Host Details: Will provide an assessment for the target system based on the scan

Task 3: Information Gathering

- Use tabs to navigate and gather information



Scans: Shows all the scans that have been conducted or are ongoing. Used to switch between scans.

Note: To keep clutter to minimum, click on the old scans and select Remove Scan.

Task 3: Information Gathering

- Using online tool NetCraft (www.netcraft.com)

The screenshot shows the NetCraft website homepage. At the top is the NetCraft logo and a navigation bar with links: Home, News, Anti-Phishing, Security Testing, Internet Data Mining, Performance, and About NetCraft. A search bar is located in the top right corner. The main content area is titled "Internet Security and Data Mining" and describes the services offered. Below this is a section for "Anti-Phishing", "Security Testing", "Internet Data Mining", and "Performance". The "Performance" section is highlighted and contains a "Detailed Performance Information" box with a list of services: Network performance monitoring and site outage alerting, More than ten measurement points on separate networks, Detailed graphs of performance across multiple metrics, Opportunity to exhibit your reliability with uptime seals and a timeline integrated with social media, Monitor potential hosting customers, and Find out more. To the right of this section is a "Latest News" box with a list of recent articles. Below the news is a "Get in Touch" section with contact information. At the bottom right is a "What's that site running?" section with a search bar and a button. The bottom of the page features a "Solutions For..." section and a "Audited by Netcraft" badge.

NETCRAFT

Contact Us | Subscribe

Search Netcraft

Home News Anti-Phishing Security Testing Internet Data Mining Performance About Netcraft

Internet Security and Data Mining

Netcraft provide internet security services including anti-fraud and anti-phishing services, application testing and PCI scanning. We also analyse many aspects of the internet, including the market share of web servers, operating systems, hosting providers and SSL certificate authorities.

Anti-Phishing **Security Testing** **Internet Data Mining** **Performance**

NETCRAFT

Detailed Performance Information

- Network performance monitoring and site outage alerting
- More than ten measurement points on separate networks
- Detailed graphs of performance across multiple metrics
- Opportunity to exhibit your reliability with uptime seals and a timeline integrated with social media
- Monitor potential hosting customers
- Find out more

Monitor your performance

Latest News

- Most Reliable Hosting Company Sites In February 2018
- nginx, Nginx, NGINX, or NGINX?
- February 2018 Web Server Survey
- Most Reliable Hosting Company Sites In January 2018
- The hidden "well-known" phishing sites

Get in Touch

+44 (0) 1225 447500
info@netcraft.com

What's that site running?

Find out what technologies are powering any website:

netcraft.com

Audited by Netcraft

NETCRAFT
www.netcraft.com
Security Audited 2018-03-10
Click to Verify

This site is Audited by Netcraft. Get your site scanned for vulnerabilities>

Task 4: John The Ripper

- John the Ripper (JtR) is an Open Source password security auditing and password recovery tool available for many operating systems.
- JtR auto detects the encryption on the hashed data and compares it against a large plain-text file that contains popular passwords, hashing each password, and then stopping it when it finds a match.
- JtR also includes its own wordlists of common passwords for 20+ languages.
- These wordlists provide JtR with thousands of possible passwords from which it can generate the corresponding hash values to make a high-value guess of the target password
- Since most people choose easy-to-remember passwords, JtR is often very effective even with its out-of-the-box wordlists of passwords.

Task 4: John The Ripper

- Before starting the Cybersec-Server, Go to Settings and increase the RAM Allocation for better cracking ability.
- We are going to use the Cybersec-Server for this lab.

```
cybersec-server@ubuntu:~$ john
John the Ripper password cracker, version 1.8.0
Copyright (c) 1996-2013 by Solar Designer
Homepage: http://www.openwall.com/john/

Usage: john [OPTIONS] [PASSWORD-FILES]
--single                "single crack" mode
--wordlist=FILE --stdin wordlist mode, read words from FILE or stdin
--rules                enable word mangling rules for wordlist mode
--incremental[=MODE]   "incremental" mode [using section MODE]
--external=MODE        external mode or word filter
--stdout[=LENGTH]      just output candidate passwords [cut at LENGTH]
--restore[=NAME]       restore an interrupted session [called NAME]
--session=NAME         give a new session the NAME
--status[=NAME]        print status of a session [called NAME]
--make-charset=FILE    make a charset, FILE will be overwritten
--show                show cracked passwords
--test[=TIME]          run tests and benchmarks for TIME seconds each
--users=[-]LOGIN|UID[,..] [do not] load this (these) user(s) only
--groups=[-]GID[,..]   load users [not] of this (these) group(s) only
--shells=[-]SHELL[,..] load users with[out] this (these) shell(s) only
--salts=[-]N           load salts with[out] at least N passwords only
--save-memory=LEVEL    enable memory saving, at LEVEL 1..3
--node=MIN[-MAX]/TOTAL this node's number range out of TOTAL count
--fork=N              fork N processes
```

Task 4: John The Ripper

John the Ripper works in 3 distinct modes to crack passwords:

- Single mode: is the fastest and best mode if you have a full password file to crack.
- Wordlist mode: compares the hash to a known list of potential password matches.
- Incremental mode: is brute force mode that tries every possible character combination until find a possible result.

Task 4: John The Ripper

- Change to Documents directory using **cd Documents/**. Next, do an **ls** to list out the files in the directory, you will find “**mypasswd**” file, check the content of the mypasswd using **cat mypasswd**.
- This file includes user’s name and their encrypted password

```
cybersec-server@ubuntu:~/Documents$ cat mypasswd
cybersec-server:$6$.HzX0ral$x.ie52E8I4ZC1/FTbiqsEWlG/hH7eriilzDr7c/XBbniBCixgHej
1000:1000:CyberSec:/home/cybersec-server:/bin/bash
Alice:$6$pHP7TsIr$Y5LNFbieD4kdaGhp9jcDo532St./a6.bLlgaJtq7588HBWDDyevB9/oksQR6oA
:/home/Alice:
Eric:$6$qYmN1.xs$L1nwW.S46Yx4ciCyamvSW6vlf1QmPnGbI2QIeCRLPs7bluJpjCpbDMezsBw0Yoy
/home/Eric:
Bob:$6$ZqiJ2Ai/$aHiRq4wX0EZQvBnzeA8w6VhQDVUKNSGmM7IeyloQ3/z34QzRE4/GmNAI6UP4I.R.
home/Bob:
Eve:$6$ydZ/4DCp$3cWJ/Kq1r0aqpj5AFZ/SKc0N/9aPkgRvH2m2DRwTdgaaJ9.oEr0T09XecyKzceIq
home/Eve:
```

Task 4: John The Ripper

Step 2: Recover Passwords

- Type the following command in terminal:
 - `cybersec-server@ubuntu:~$ john --show mypasswd`

```
cybersec-server@ubuntu:~/Documents$ john --show mypasswd
0 password hashes cracked, 5 left
cybersec-server@ubuntu:~/Documents$ █
```

There are no cracked passwords at this point.

Task 4: John The Ripper

- At the command prompt, enter `john mypasswd` to use **single crack mode**. You can see the password for `cybersec-server` is cracked instantly, user Alice and Bob's password are cracked in seconds.

```
cybersec-server@ubuntu:~$ john mypasswd
```

```
cybersec-server@ubuntu:~/Documents$ john mypasswd
Loaded 5 password hashes with 5 different salts (crypt, generic crypt(3) [?/64])
Press 'q' or Ctrl-C to abort, almost any other key for status
cybersec          (cybersec-server)
password          (Alice)
123456            (Bob)
```

Password cracking is CPU-intensive and a very long process, so the time it takes will depend on your system and the strength of the password. It can take days. If the password is not cracked for days with a powerful CPU, it is a very good password.

Task 4: John The Ripper

- Use Ctrl-C to abort the program after couple of minutes, then use john --show mypasswd to check the same file again, we find there are 3 passwords cracked, 2 left.

```
cybersec-server@ubuntu:~/Documents$ john --show mypasswd
cybersec-server:cybersec:1000:1000:CyberSec:/home/cybersec-server:/bin/bash
Alice:password:1002:1002::/home/Alice:
Bob:123456:1004:1004::/home/Bob:

3 password hashes cracked, 2 left
```

- JtR uses a predefined dictionary called password.lst(in /usr/share/john directory) with a standard set of predefined “rules” for handling the dictionary and retrieves all password hashes of both md5crypt and crypt type, we have copied this file to our working directory and modified it.

Task 4: John The Ripper

- Now let's use wordlist mode to crack the remaining passwords. This time user Eve's password is cracked instantly, that is because the password.lst file include this password.
- If it shows locked(crash recovery file is locked), use **sudo john mypasswd --wordlist="password.lst"**

```
cybersec-server@ubuntu:~/Documents$ john mypasswd --wordlist="password.lst"
Loaded 5 password hashes with 5 different salts (crypt, generic crypt(3) [?/64])
Remaining 2 password hashes with 2 different salts
Press 'q' or Ctrl-C to abort, almost any other key for status
Pa$$w0rd (Eve)
lg 0:00:00:11 34% 0.08703g/s 91.90p/s 100.2c/s 100.2C/s seattle..789456
Use the "--show" option to display all of the cracked passwords reliably
Session aborted
```

Task 4: John The Ripper

- The results below display the passwords for each account.

```
cybersec-server@ubuntu:~/Documents$ john --show mypasswd
cybersec-server:cybersec:1000:1000:CyberSec:/home/cybersec-server:/bin/bash
Alice:password:1002:1002::/home/Alice:
Bob:123456:1004:1004::/home/Bob:
Eve:Pa$$w0rd:1005:1005::/home/Eve:
4 password hashes cracked, 1 left
```


Task 4: John The Ripper

- Mangling is a preprocessor in JtR that optimizes the wordlist to make the cracking process faster. Use the `--rules` parameter to set the mangling rules if you wish.

```
cybersec-server@ubuntu:~/Documents$ john --wordlist=password.lst --rules mypasswd
```

Task 4: John The Ripper

Challenge:

1. Can you find out the password for user Eric?
2. What did you learn from password cracking process? How to create secure password?

Extra

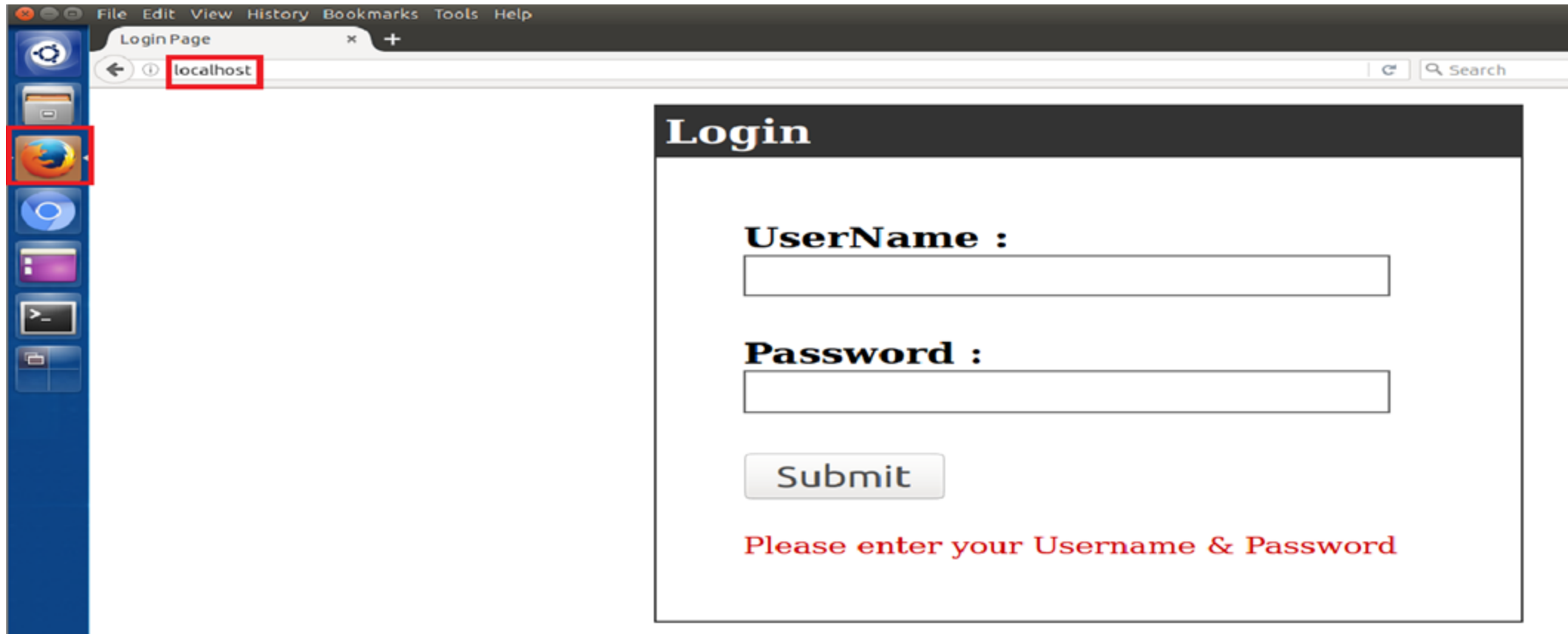
- You can check the strength of password here:
<https://www.passwordmonster.com/>

Task 5: SQL Injection

- SQL injection is an attack injection technique that exploits vulnerability in SQL query via user's input data from client to the database layer of an application.
- This vulnerability exists in custom Web application that lacks proper input validation, fails to use parameterized SQL statements, and/or creates dynamic SQL with user-supplied data.
- Attacker will test SQL injection by typing malformed SQL commands into front-end Web application input boxes that are tied to database accounts to trick the database into offering more access to information than the developer intended.
- This attack allows attackers to spoof identity, tamper with existing data, cause repudiation issues such as voiding transactions or changing balances, destroy the data and become administrators of the database server.

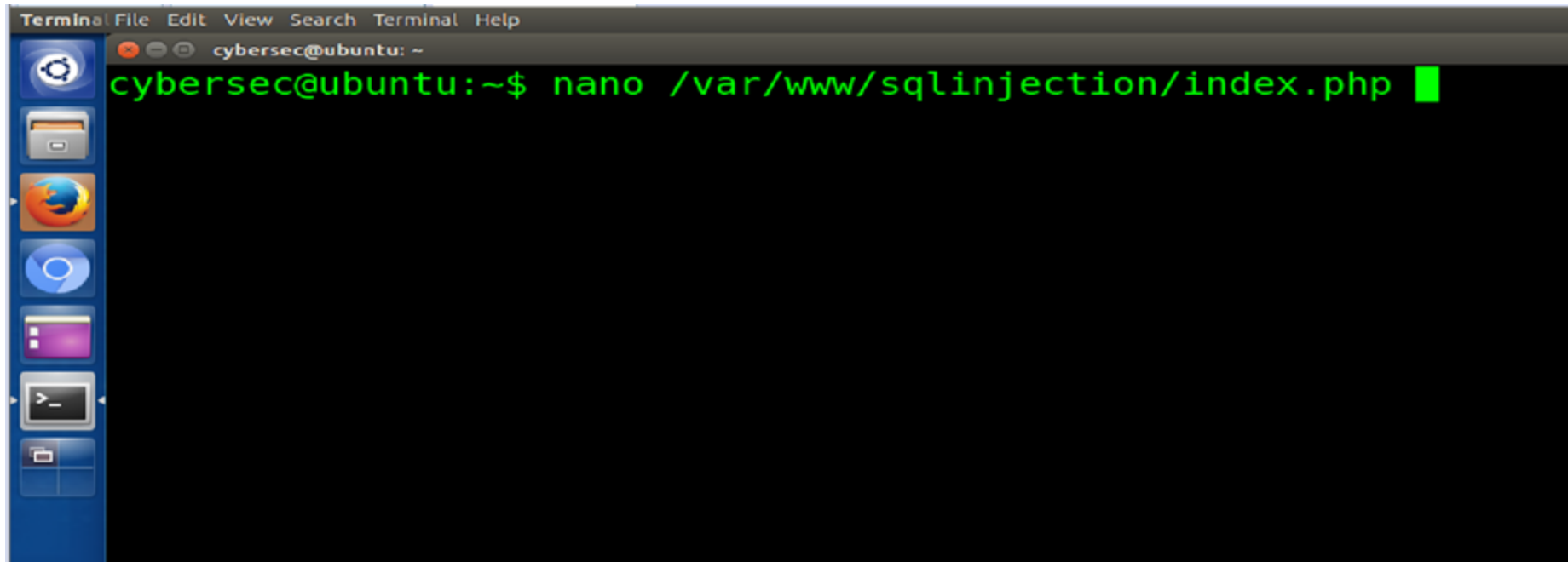
Task 5: SQL Injection(10.0.2.6)

- Open Firefox on the Server VM and enter localhost in the address bar.



Task 5: SQL Injection

- Let's look at the source file

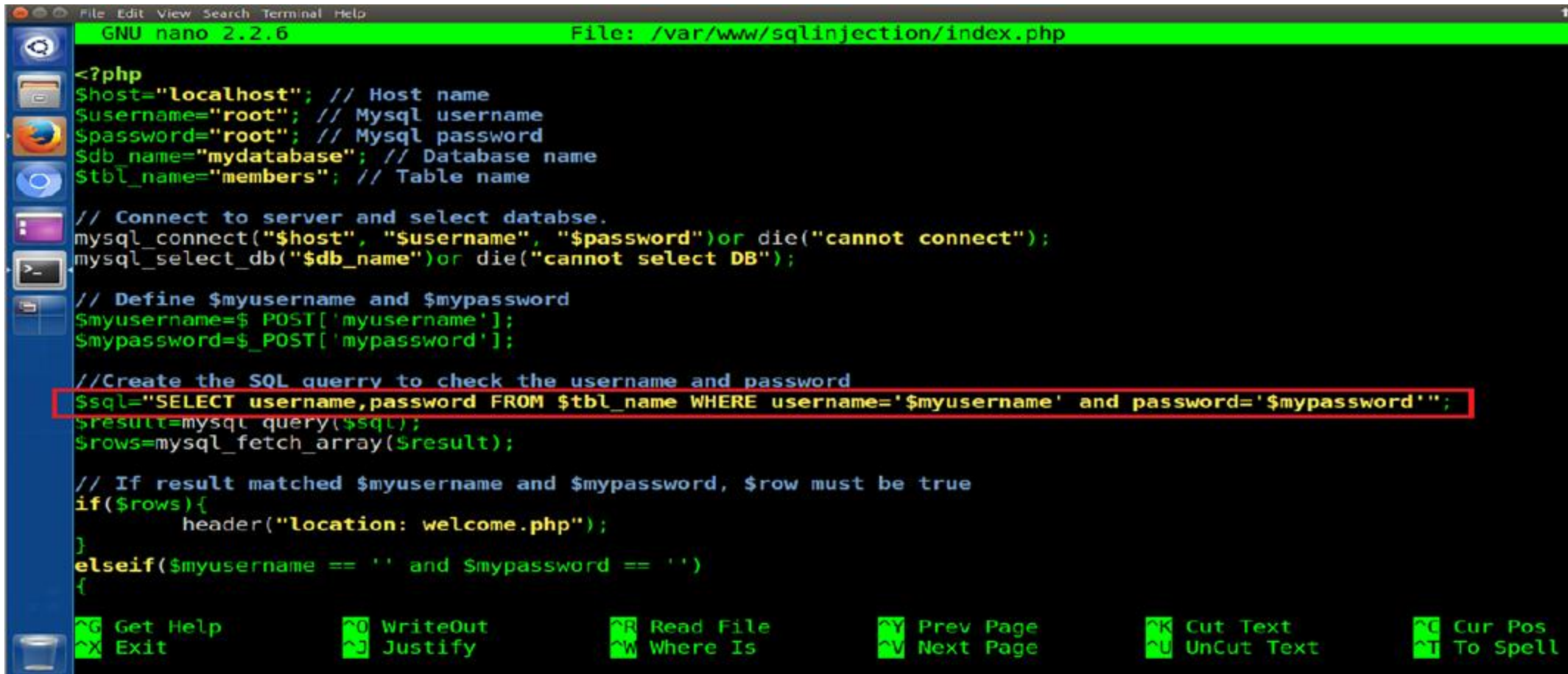


A terminal window on an Ubuntu system. The window has a title bar with 'Terminal' and menu options 'File', 'Edit', 'View', 'Search', 'Terminal', and 'Help'. The prompt is 'cybersec@ubuntu: ~'. The command 'nano /var/www/sqlinjection/index.php' has been entered, and a green cursor is at the end of the line. On the left side of the terminal, there is a vertical dock with icons for Dash, Home, Firefox, LibreOffice, and the terminal itself.

```
Terminal File Edit View Search Terminal Help
cybersec@ubuntu: ~
cybersec@ubuntu:~$ nano /var/www/sqlinjection/index.php
```

Task 5: SQL Injection

- Note: Use CTRL + X to exit the text editor



```
GNU nano 2.2.6 File: /var/www/sqlinjection/index.php

<?php
$host="localhost"; // Host name
$username="root"; // Mysql username
$password="root"; // Mysql password
$db_name="mydatabase"; // Database name
$table_name="members"; // Table name

// Connect to server and select database.
mysql_connect("$host", "$username", "$password")or die("cannot connect");
mysql_select_db("$db_name")or die("cannot select DB");

// Define $myusername and $mypassword
$myusername=$_POST['myusername'];
$mypassword=$_POST['mypassword'];

//Create the SQL query to check the username and password
$sql="SELECT username,password FROM $table_name WHERE username='$myusername' and password='$mypassword'";
$result=mysql_query($sql);
$rows=mysql_fetch_array($result);

// If result matched $myusername and $mypassword, $row must be true
if($rows){
    header("location: welcome.php");
}
elseif($myusername == '' and $mypassword == '')
{
    // ... (rest of the script) ...
}

^G Get Help      ^O WriteOut      ^R Read File     ^Y Prev Page     ^K Cut Text       ^C Cur Pos
^X Exit          ^J Justify       ^W Where Is      ^V Next Page     ^U UnCut Text    ^T To Spell
```

Task 5: SQL Injection

• <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>

• <https://sechow.com/bricks/docs/login-1.html>

• Refer to the links provided above to perform the following tasks:

1. Login with Username as '123456789' and the Password as a SQL command to gain unauthorized access. **'or'1'='1'**

2. Login with both Username and Password as SQL commands.

3. Find table details containing all the Usernames and Passwords through SQL injection. **'or'1'='1' into outfile'/tmp/sql.txt'#** (enter this as username and password)

4. Login into a specific user account by extracting the username and password from the table.

Task 6: Port Scanning

Q1. Run an aggressive port scan to scan all ports on cybersec-server (10.0.2.6) and cybersec-client(10.0.2.8) from **cybersec-attacker**. Provide screenshots of the port scan report.

Keep all 3 VM's open simultaneously and perform the activity from cybersec-attacker